

Brian J. Scott

hello@briscosec.io · github.com/therealartifex · linkedin.com/in/brian-scott-1765b9aa

PROFESSIONAL SUMMARY

Security research engineer with four years at Cisco's Advanced Security Initiatives Group (ASIG) conducting crystal-box product security evaluations across cloud, network, web application, and LLM attack surfaces, with findings integrated into Cisco's Secure Development Lifecycle. Co-author of CVE-2022-38060 (CVSS 3.1: 7.8). Technical depth spans exploit development, dynamic instrumentation, malware development, EDR evasion, and SCADA protocol analysis. Independently operates a large-scale breach intelligence corpus with a custom Python and ClickHouse analysis pipeline supporting OSINT and forensic investigations. Holds GXPN, GCPN, OSCP, and CRTO.

EXPERIENCE

Security Research Engineer

Apr. 2022–Mar. 2026

Cisco Systems, Inc. – Advanced Security Initiatives Group (ASIG)

- Conducted crystal-box product security evaluations over four years across enterprise network, cloud, web application, and AI products; built adversary-perspective attack models and traced complete exploit chains from initial vulnerability to maximum product exposure; findings integrated into Cisco's Secure Development Lifecycle.
- Co-authored **CVE-2022-38060** (CVSS 3.1: 7.8): local privilege escalation via `sudoers` PATH manipulation in OpenStack Kolla; published by Cisco Talos (TALOS-2022-1589).
- Identified a complete JWT signature verification bypass via static analysis, enabling authentication bypass and arbitrary privilege escalation across all protected endpoints of a web application.
- Reviewed transport security of a distributed network security platform; confirmed unauthenticated RPC channels via passive capture of plaintext credentials, and demonstrated unauthenticated injection of arbitrary firewall rules into hardware-accelerated enforcement.
- Traced a cleartext password lifecycle through a two-stage TPM decryption architecture, using Frida to hook Windows cryptographic APIs during live authentication; delivered memory-sanitization remediation.
- Developed PoC exploits in Go, C++, and PowerShell; evaluated an LLM-integrated product via prompt injection, bypassing guardrails to demonstrate unauthorized data access; briefed findings to product teams and division-wide readout sessions.

Founder and Principal Analyst

Apr. 2021–Present

Southwest Valley Research Group

- Built and operate a large-scale breach intelligence corpus spanning hundreds of datasets (breach dumps, stealer logs, ransomware leaks); designed the full pipeline from collection through ingestion, parsing, normalization, and analysis using custom Python tooling and ClickHouse.
- Conduct OSINT investigations and breach-data correlation for identity attribution; produce intelligence products that have supported law enforcement referrals.
- Provide forensic OSINT and breach-data analysis to legal professionals in support of civil and criminal matters.

Penetration Tester

2021

Gray Station CPAs PC, Gray, TN – Contract Engagement

- Conducted physical and network penetration testing, social engineering, and OSINT investigation for a defined-scope assessment; delivered a formal report with prioritized remediation guidance and staff security training recommendations.

- Discovered broadcast amplification and packet replay vulnerabilities in a proprietary industrial SCADA protocol (Host Automation Protocol) through Wireshark traffic analysis; reported findings leading to remediation in deployed water treatment and energy infrastructure.
- Developed PLC programming software in MFC and C++ for industrial automation product lines.

SELECTED PROJECTS

- **CVE-2022-38060 – OpenStack Kolla** (CVSS 3.1: 7.8, High): Co-discovered local privilege escalation via `sudoers` PATH manipulation enabling arbitrary command execution as root from within a containerized OpenStack deployment. Published by Cisco Talos, Dec. 2022. TALOS-2022-1589
- **fff – Fast Find in Files**: SIMD/AVX-optimized, multi-threaded file search tool in C++, purpose-built for stealer log analysis; distributes file chunks across all cores and outperforms `grep` at all tested file sizes. github.com/therealartifex/fff
- **Hashcat Module – Ruby on Rails RESTful Auth Hashes**: Developed a native hashcat cracking module eliminating manual preprocessing for this hash type; merged into the official project. PR #2914
- **Threat Intelligence and Detection Research Platform** (in progress): Multi-tier security research environment spanning network segmentation, PKI, SSO with hardware-backed MFA, and 802.1X authentication, with telemetry-based detection and a multi-backend analytics stack (ClickHouse, Qdrant, Neo4j) plus a local RAG pipeline for analyst-facing intelligence synthesis.

EDUCATION

Bachelor of Science, Computer Science

2018

Network Security Concentration · Minor in Applied Sciences

LeTourneau University, Longview, TX

TexSAW CTF (UT Dallas): competed three of four years; team placed 1st, 2017.

CERTIFICATIONS AND TRAINING

- GIAC Exploit Researcher and Advanced Penetration Tester (GXPN) – 2024
- GIAC Cloud Penetration Tester (GCPN) – 2022, exp. Nov. 2026
- Offensive Security Certified Professional (OSCP) – 2022
- Zero-Point Security Certified Red Team Operator (CRTO) – 2021
- Sektor7 Institute: Red Team Operations – Malware Development, EDR Evasion, and Windows Privilege Escalation

TECHNICAL SKILLS

Offensive Security and AppSec: Crystal-box and black-box product security evaluation; web app testing (Burp Suite, Nuclei); cloud assessment (Pacu, AWS); network penetration testing; adversary emulation (Cobalt Strike); dynamic instrumentation (Frida); malware development and EDR evasion; exploit research and PoC development; static analysis and code review (Semgrep, Trufflehog).

AI Security: LLM prompt injection; guardrail bypass; agentic pipeline attack surface assessment; AI-assisted static analysis in vulnerability research; RAG pipeline design (Qdrant).

Detection, Threat Intel, and OSINT: ClickHouse, Elasticsearch, Splunk, Zeek, Suricata, Grafana, Fluentbit, XWays Forensics, Maltego; breach data correlation, threat actor attribution, digital footprint analysis, forensic OSINT.

Security Architecture and Infrastructure: PKI, TLS/mTLS, JWT, SSH CA (Ed25519), MFA/WebAuthn, 802.1X/EAP, Keycloak/OIDC, FreeRADIUS, Active Directory, VLAN segmentation, firewall policy; Proxmox VE, Linux, FreeBSD, AWS, Kubernetes, Windows Server.

Programming: C/C++ (Windows API, SIMD/AVX, in-memory shellcode), Python, PowerShell, C#, Go, SQL.